

Fundamentos de segurança Cibernética

Locky

Lorenzo Meyer
Artur Guimarães
Pedro Webber

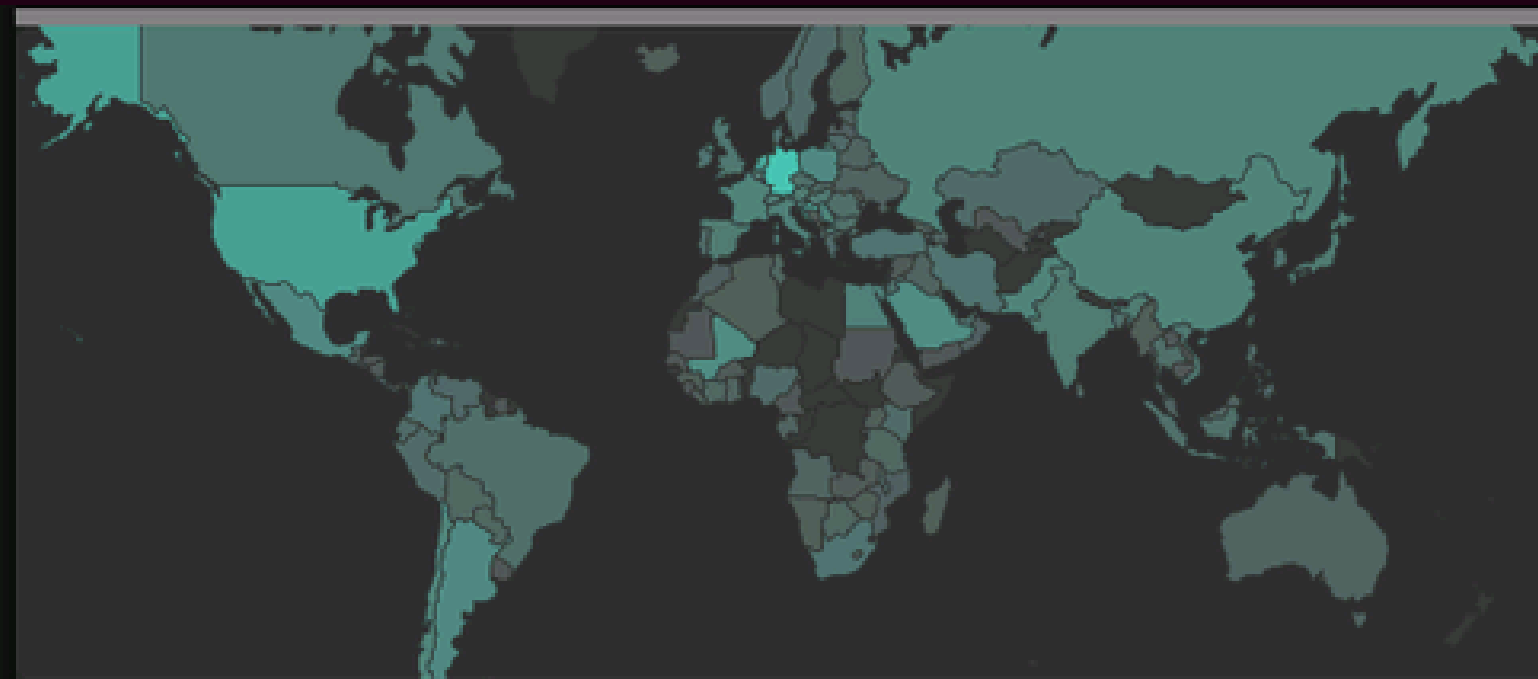
Prof. Luciano Ignaczak

Sobre o Locky:

O Locky é um tipo de malware que pode criptografar arquivos importantes no computador e mantê-los reféns enquanto exige um pagamento de resgate.

Ele conta com técnicas de engenharia social para acessar os computadores das vítimas, e o e-mail é o vetor de transmissão preferido.

Regiões atacadas e alvos



Top User Countries			
5.3K	Germany	1.2K	Saudi Arabia
2.9K	Netherlands	1.0K	Mexico
2.7K	United States	1.0K	Poland
2.1K	Croatia	959	Argentina
1.2K	Mali	840	Serbia

Esse ransomware surgiu em 2016 e se espalhou rapidamente por várias regiões do mundo, incluindo América do Norte, Europa e Ásia. Tem como principais alvos empresas dos setores de saúde, telecom e transporte.

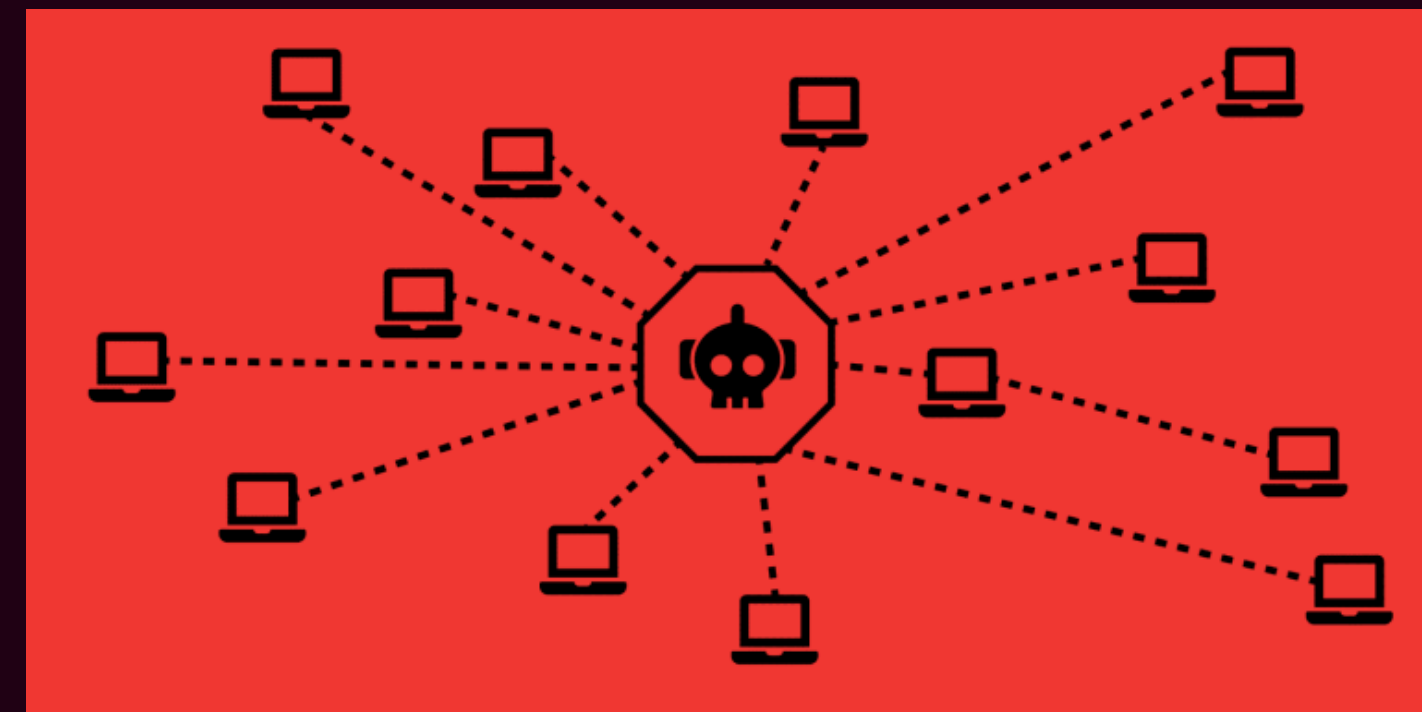
Um dos primeiros grandes ataques teve como alvo um hospital em Los Angeles, que foi forçado a pagar o resgate no valor de US\$ 17.000.

Uma campanha incessante contra outras instituições de saúde continuou durante todo o ano. Desde então, não houve outros ataques significativos do Locky.

Botnet Necurs

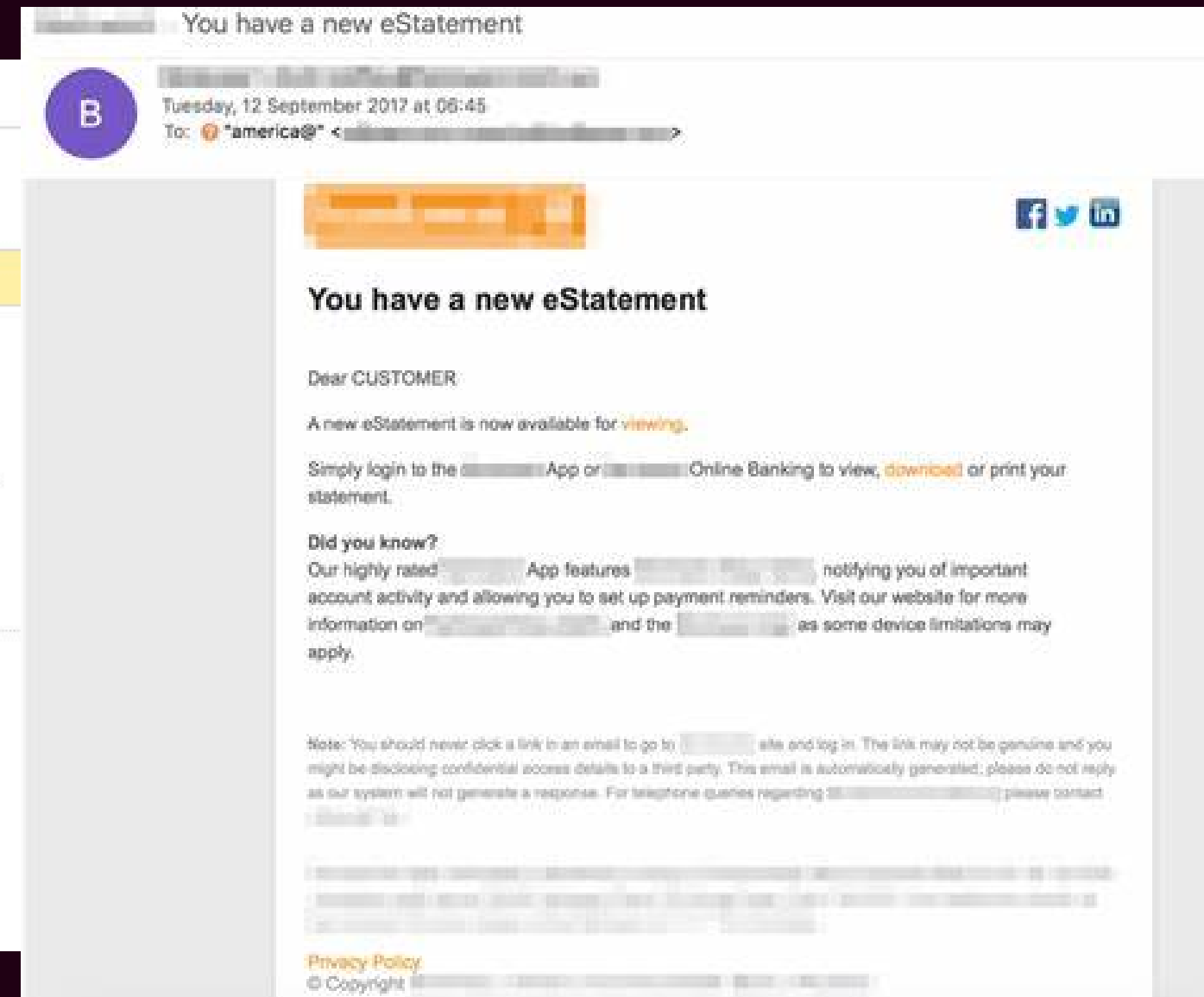
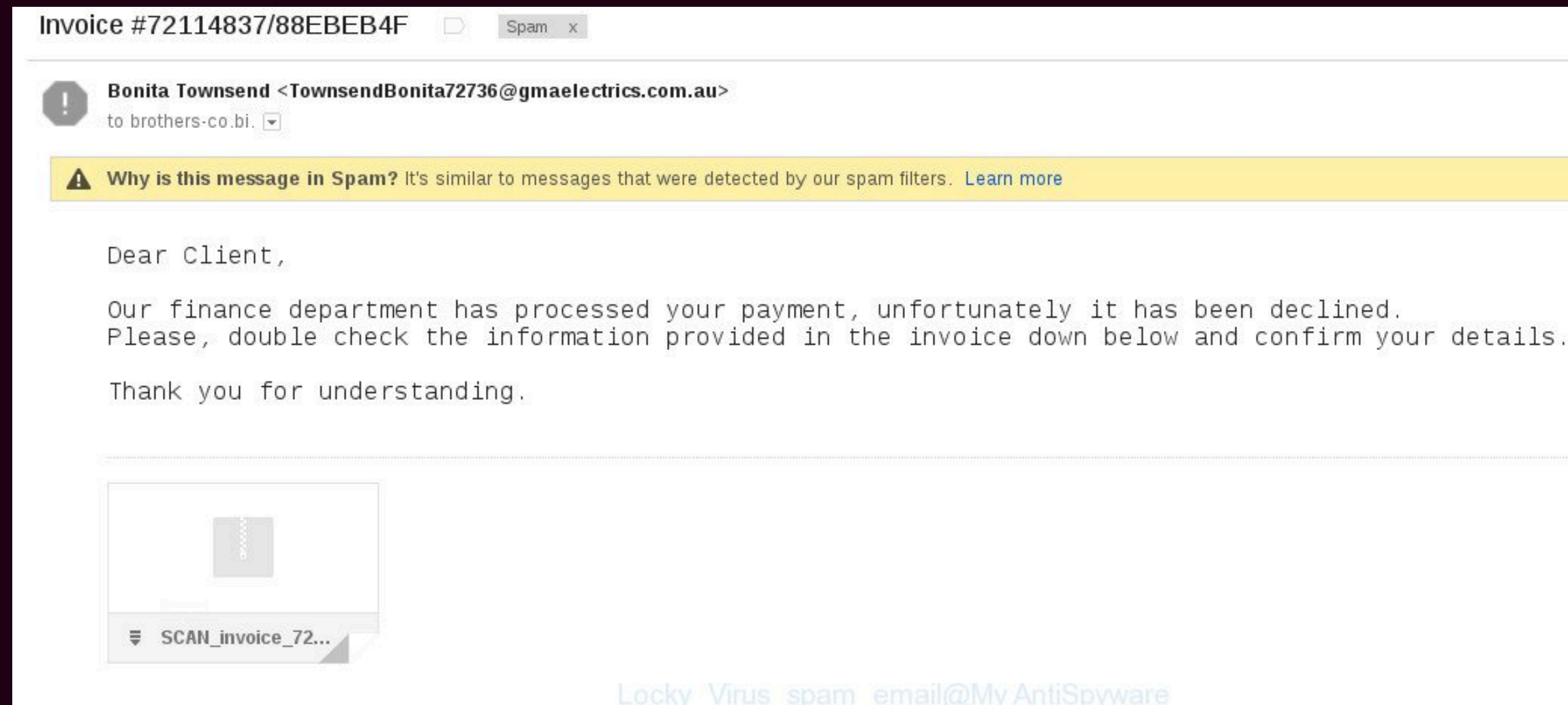
Com o intuito de contornar os sistemas de Spam, os criminosos criaram uma botnet. Tanto o grupo de hackers como a botnet são chamados de Necurs

o sistema de Spam filtra endereços IP da "lista negra" e nomes de domínio que enviam muitos e-mails. Ao espalhar a tarefa de enviar os e-mails, a Necurs evita esse filtro. Os domínios de origem fornecidos nesses e-mails geralmente são falsos. Não é necessário que os destinatários respondam, basta abrir o anexo.

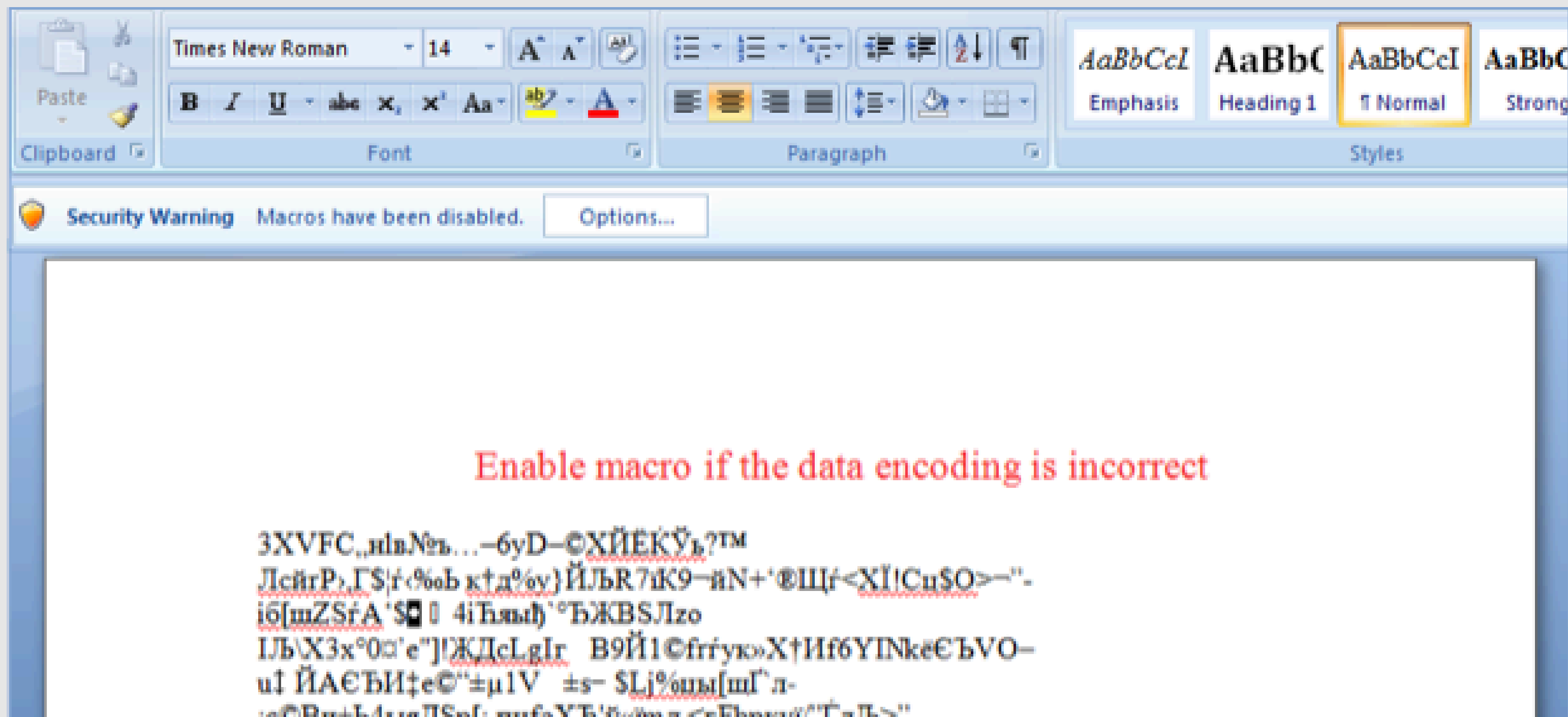


vetores

Distribuído principalmente por campanhas de spam, também pode ser distribuído com uso de exploit kits (Neutrino e Rig)



- **A vitima recebe um e-mail com um documento em anexo**
- **O documento não é legível e possui a mensagem "Enable macros if the data encoding is incorrect".**
- **se os macros são ativados, o documento não é corrigido e sim um código dentro do documento é rodado na máquina. Esse código salva e roda um arquivo no disco do computador.**
- **O arquivo serve como downloader que traz o payload final do malware**



The criminals want you to click [Options...] and turn macros on. Don't do it!

o Locky criptografa com RSA-2048 e AES-128 todos os arquivos com as extensões abaixo:

.mid, .wma, .flv, .mkv, .mov, .avi, .asf, .mpeg, .vob, .mpg, .wmv, .fla, .swf, .wav, .qcow2, .vdi, .vmdk, .vmx, .gpg, .aes, .ARC, .PAQ, .tar.bz2, .tbk, .bak, .tar, .tgz, .rar, .zip, .djv, .djvu, .svg, .bmp, .png, .gif, .raw, .cgm, .jpeg, .jpg, .tif, .tiff, .NEF, .psd, .cmd, .bat, .class, .jar, .java, .asp, .brd, .sch, .dch, .dip, .vbs, .asm, .pas, .cpp, .php, .ldf, .mdf, .ibd, .MYI, .MYD, .frm, .odb, .dbf, .mdb, .sql, .SQLITEDB, .SQLITE3, .asc, .lay6, .lay, .ms11 (Security copy), .sldm, .sldx, .ppsm, .ppsx, .ppam, .docb, .mml, .sxm, .otg, .odg, .uop, .potx, .potm, .pptx, .pptm, .std, .sxd, .pot, .pps, .sti, .sxi, .otp, .odp, .wks, .xltx, .xltn, .xlsx, .xlsm, .xlsb, .slk, .xlw, .xlt, .xlm, .xlc, .dif, .stc, .sxc, .ots, .ods, .hwp, .dotm, .dotx, .docm, .docx, .DOT, .max, .xml, .txt, .CSV, .uot, .RTF, .pdf, .XLS, .PPT, .stw, .sxw, .ott, .odt, .DOC, .pem, .csr, .crt, .key, wallet.dat

Além de apagar todos os arquivos gerados por VSS (shadow copies)

Assim que pronto, locky substitui o papel de parede pelo da imagen:

!!! IMPORTANT INFORMATION !!!!

All of your files are encrypted with RSA-2048 and AES-128 ciphers.

More information about the RSA and AES can be found here:

[http://en.wikipedia.org/wiki/RSA_\(cryptosystem\)](http://en.wikipedia.org/wiki/RSA_(cryptosystem))

http://en.wikipedia.org/wiki/Advanced_Encryption_Standard

Decrypting of your files is only possible with the private key and decrypt program, which is on our secret server.

To receive your private key follow one of the links:

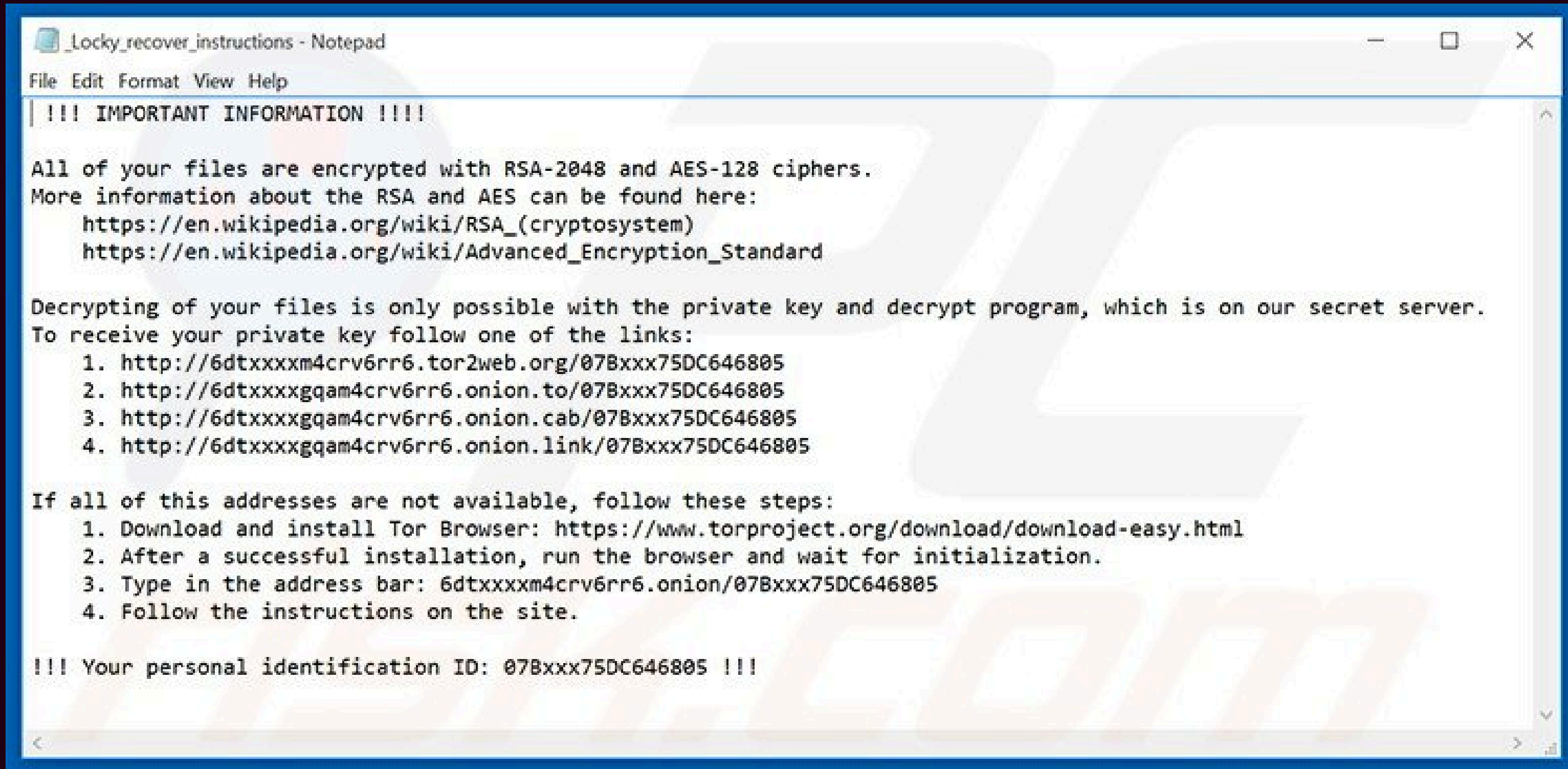
1. <http://6dtxgqam4crv6rr6.tor2web.org/F99C410F07678BEF>
2. <http://6dtxgqam4crv6rr6.onion.to/F99C410F07678BEF>
3. <http://6dtxgqam4crv6rr6.onion.cab/F99C410F07678BEF>
4. <http://6dtxgqam4crv6rr6.onion.link/F99C410F07678BEF>

If all of this addresses are not available, follow these steps:

1. Download and install Tor Browser: <https://www.torproject.org/download/download-easy.html>
2. After a successful installation, run the browser and wait for initialization.
3. Type in the address bar: 6dtxgqam4crv6rr6.onion/F99C410F07678BEF
4. Follow the instructions on the site.

!!! Your personal identification ID: F99C410F07678BEF !!!

arquivo _Locky_recover_instructions.txt



```
_Locky_recover_instructions - Notepad
File Edit Format View Help
| !!! IMPORTANT INFORMATION !!!!

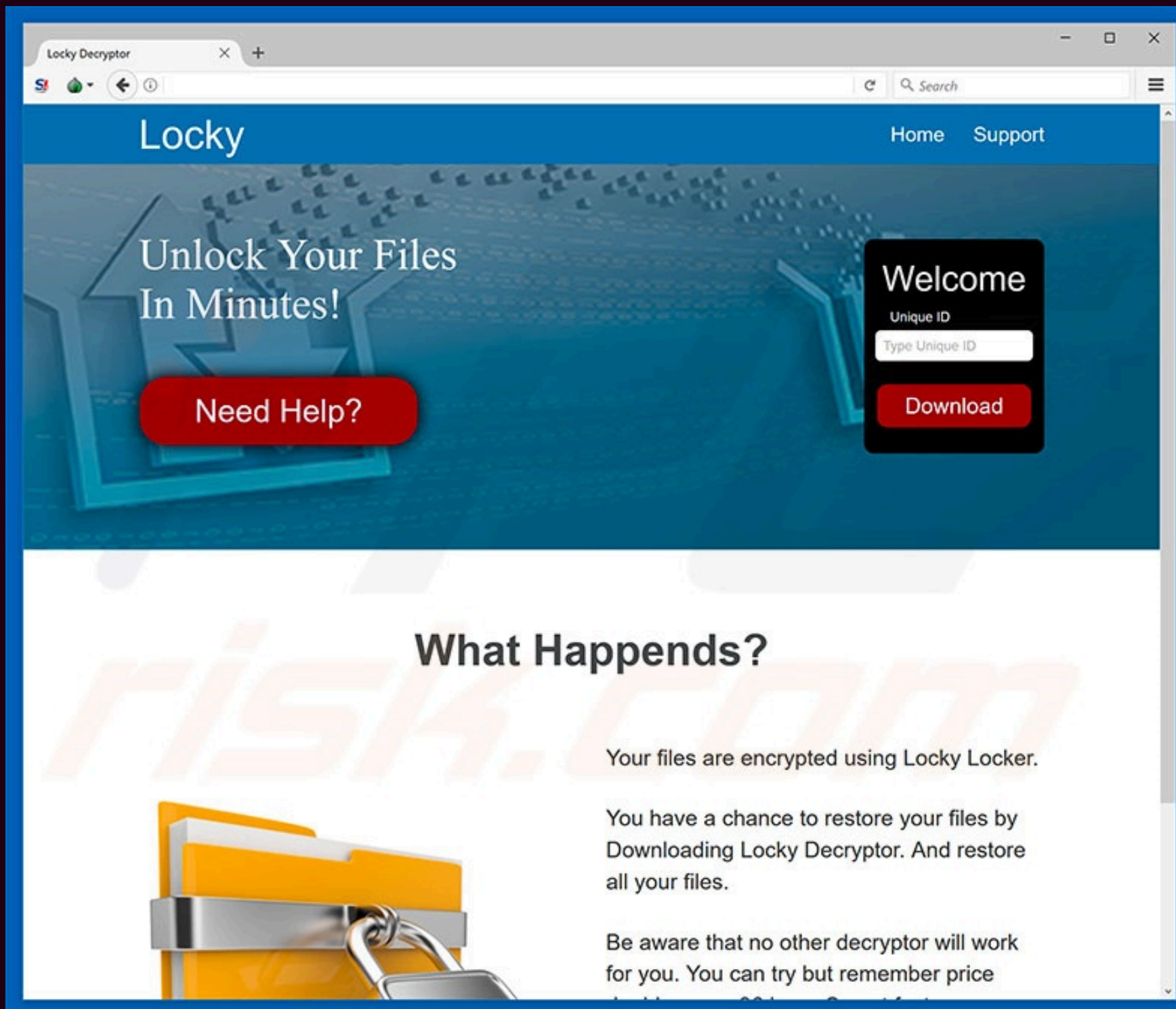
All of your files are encrypted with RSA-2048 and AES-128 ciphers.
More information about the RSA and AES can be found here:
  https://en.wikipedia.org/wiki/RSA_(cryptosystem)
  https://en.wikipedia.org/wiki/Advanced_Encryption_Standard

Decrypting of your files is only possible with the private key and decrypt program, which is on our secret server.
To receive your private key follow one of the links:
  1. http://6dtxxxxm4crv6rr6.tor2web.org/07Bxxx75DC646805
  2. http://6dtxxxgqam4crv6rr6.onion.to/07Bxxx75DC646805
  3. http://6dtxxxgqam4crv6rr6.onion.cab/07Bxxx75DC646805
  4. http://6dtxxxgqam4crv6rr6.onion.link/07Bxxx75DC646805

If all of this addresses are not available, follow these steps:
  1. Download and install Tor Browser: https://www.torproject.org/download/download-easy.html
  2. After a successful installation, run the browser and wait for initialization.
  3. Type in the address bar: 6dtxxxxm4crv6rr6.onion/07Bxxx75DC646805
  4. Follow the instructions on the site.

!!! Your personal identification ID: 07Bxxx75DC646805 !!!
```

O website possui informações de como comprar o software para descriptografar, além de ensinar a criar uma carteira e comprar bitcoin.



We present a special software - **Locky Decryptor** - which allows to decrypt and return control to all your encrypted files.

How to buy Locky decrypter?

1. You can make a payment with BitCoins, there are many methods to get them.

 **bitcoin**

2. You should register BitCoin wallet (simplest online wallet OR some other methods of creating wallet)
3. Purchasing Bitcoins - Although it's not yet easy to buy bitcoins, it's getting simpler every day.

Here are our recommendations:

- LocalBitcoins.com (WU) - Buy Bitcoins with Western Union
- Coincafe.com - Recommended for fast, simple service.

As demandas típicas de resgate variam de 0,5 a 1,0 Bitcoin (BTC).

Assim que instalado ele se comunica com o C&C para trocar as keys:

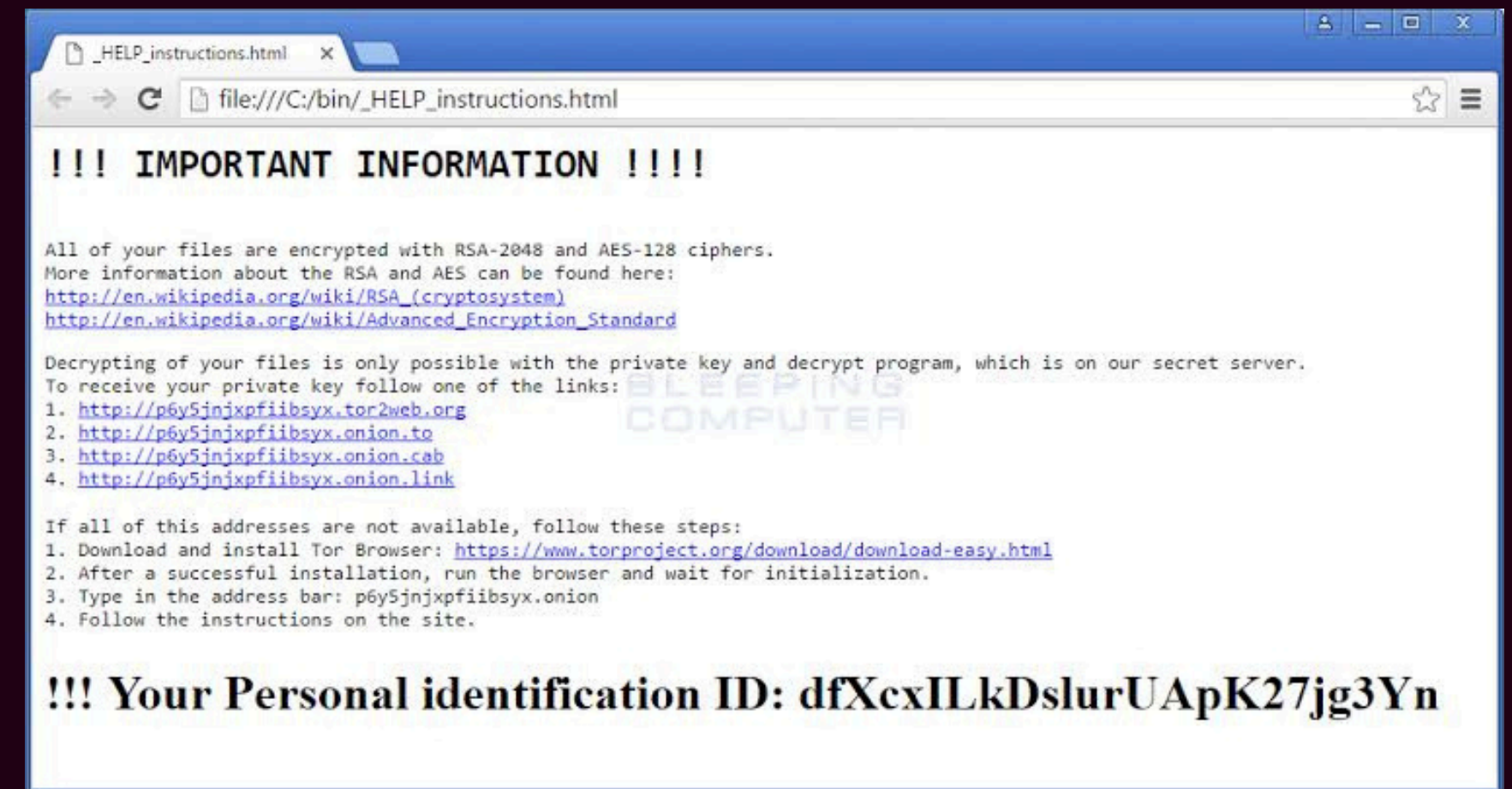
- **Ele usa uma lista de endereços IP para estabelecer uma sessão TCP**
- **Se a conexão com esses IPs falhar ele roda um Domain Generation Algorithm (DGA) que gera periodicamente uma grande quantidade de nomes de domain pseudo-aleatorios. Locky continua mandando pedidos DNS até encontrar o C&C.**
- **Se o DGA também falhar, Locky usa o protocolo NetBIOS Name System (NBNS) tentando encontrar uma maquina previamente invadida que tenha contato com o C&C**

Assim que conectado usa um pedido HTTP POST para enviar informações de volta ao atacante

variantes

PowerLocky: É uma mistura de dois sistemas de ransomware: Locky e PowerWare. Software de extorsão baseado em criptografia, é distribuído como um executável .NET escrito em PowerShell. Como o Locky original, o PowerLocky altera os nomes de todos os arquivos criptografados e coloca a extensão .locky neles. A nota de resgate do PowerLocky é uma cópia exata daquela usada por Locky.

Lukitus: surgiu em agosto de 2017. O Necurs também distribuiu esse tipo de Locky como um anexo de um e-mail. “ Lukitus ” é traduzido do finlandês para “bloqueio”. Na campanha Lukitus, o anexo era um arquivo .zip ou .rar, e o código infectado foi escrito em JavaScript ou VBScript. Os arquivos infectados obtêm a extensão .lukitus. Depois de concluir sua criptografia, o executável primário é removido.



Referências

- **How Just Opening an MS Word Doc Can Hijack Every File On Your System (thehackernews.com)**
- **A Multi-Classfier Network-Based Crypto Ransomware Detection System: A Case Study of Locky Ransomware | IEEE Journals & Magazine | IEEE Xplore**
- **“Locky” ransomware – what you need to know – Naked Security (sophos.com)**
- **Ransomware Locky - Desencrytação, remoção, e recuperação de ficheiros perdidos (atualizado) (pcrisk.pt)**